Engineering Security Policy

1. Secrets Management

Never commit secrets, API keys, or credentials to git. Use the approved secrets manager and inject values at runtime. If a secret is leaked, rotate it immediately and report the incident to the security team.

2. Access Control

Production access is granted on a least-privilege basis and reviewed quarterly. VPN is mandatory for any access to internal systems from outside the office network. Shared accounts are prohibited.

3. Dependency Management

Dependencies must be pinned and scanned weekly for vulnerabilities. Critical vulnerabilities must be patched within 7 days, high severity within 30 days. Adding a new third-party library requires a security review.

4. Incident Response

Report suspected incidents to security@acme.example within 1 hour of discovery. The on-call engineer must acknowledge within 15 minutes. A post-incident review is required within 5 business days for any severity-1 incident.